

DocuControl — OWASP-Sicherheitsbericht: Pi-Host-Ebene (Update nach Passwort-Rollout)

Gerät: docucontrol3 / Pi5_Display (192.168.0.218 / .11), Raspberry Pi 5, Debian Trixie
Prüfmethode: Live-Systemaudit über SSH, erneut durchgeführt nach den Fixes vom 22.06.2026
Datum: 22.06.2026 (Re-Audit) **Vorgänger:** docucontrol_owasp_host_sicherheitsbericht.md (Erstaudit, selbiger Tag)

Zusammenfassung

Seit dem Erstaudit wurden auf **diesem Gerät** vier der fünf empfohlenen Maßnahmen umgesetzt: rpcbind deaktiviert, SSH auf Key-only umgestellt, sowie SSH/sudo- und Web-UI-Service-Passwort individuell gesetzt. Alle Änderungen wurden live verifiziert. **Verbleibend offen** ist ausschließlich die Docker-Privilegienreduktion (bewusst zurückgestellt, siehe Begründung) sowie der flotten-weite Rollout auf die beiden aktuell nicht erreichbaren Geräte (DocuControl .171, DocuPi-3000 .83) und das SMB-Konto auf 192.168.0.86.

#	Befund aus Erstaudit	Status jetzt
1.1	Gemeinsames Klartext-Passwort, in CLAUDE.md dokumentiert	✔ für dieses Gerät behoben (individuelles Passwort, nicht mehr in CLAUDE.md)
2.1	Docker privileged: true + network_mode: host	▮ bewusst zurückgestellt
3.1	SSH erlaubt Passwort-Authentifizierung	✔ behoben
3.2	rpcbind auf allen Interfaces erreichbar	✔ behoben
3.3	Kein fail2ban/sshguard	▮ weiterhin offen (geringe Priorität)

1. Behobene Befunde (verifiziert)

1.1 Individuelles Passwort statt geteiltem Klartext-Passwort — ✔ behoben

- Neues, kryptografisch zufälliges Passwort (22 Zeichen) für den Linux-Account docucontrol per chpasswd gesetzt.
- **Verifiziert:** altes Passwort Xtend1478 wird von sudo abgelehnt ("Das hat nicht funktioniert"), neues Passwort funktioniert.
- CLAUDE.md-Einträge für dieses Gerät zeigen keinen Klartext mehr, nur noch einen Verweis auf die lokale, git-ignorierte secrets/ -Ablage.

- Zusätzlich: das Web-UI-Service-Login-Passwort wurde **unabhängig** vom SSH-Passwort neu gesetzt (`data/auth_secrets.json`), ebenfalls verifiziert (alt → 401, neu → 200).

1.2 SSH-Passwort-Authentifizierung deaktiviert — ✓ behoben (bereits vor Rollout umgesetzt, weiterhin aktiv)

- `sshd -T` zeigt aktuell `passwordauthentication no`.
- Re-Test: Verbindung mit `PubkeyAuthentication=no` wird mit "Permission denied (publickey)" abgelehnt, normale Key-Verbindung funktioniert.

1.3 rpcbind deaktiviert — ✓ behoben, weiterhin inaktiv

- `systemctl is-enabled rpcbind` → `disabled`, `is-active` → `inactive`.
 - Port 111 ist nicht mehr in der `ss -tulnp`-Ausgabe vorhanden.
-

2. Weiterhin offene Befunde

2.1 Docker `privileged: true` + `network_mode: host` — bewusst zurückgestellt

- Unverändert gegenüber Erstaudit. Funktional begründet (CUPS, nmcli, USB-Mount, Watchdog-HAT), Reduktion auf gezielte Capabilities erfordert Einzelanalyse pro Funktion + Testfenster — nicht spontan umsetzbar ohne Ausfallrisiko.
- **Empfehlung unverändert:** in einem separaten Wartungsfenster angehen, nicht im Rahmen eines reinen Passwort-Rollouts.

2.2 Kein fail2ban/sshguard — weiterhin offen, geringe Priorität

- Weiterhin 0 fehlgeschlagene SSH-Versuche in 30 Tagen — kein akuter Handlungsdruck.
 - Durch die SSH-Key-only-Umstellung (1.2) ist das Risiko ohnehin stark gesunken: Brute-Force gegen ein Passwort ist gar nicht mehr möglich, nur noch gegen den privaten Schlüssel (praktisch irrelevant ohne dessen Diebstahl).
-

3. Flottenweiter Status (außerhalb dieses Geräts)

Gerät	SSH/sudo-Passwort	Erreichbarkeit beim letzten Versuch
Pi5_Display / docucontrol3 (.218)	✓ individuell, rotiert	erreichbar
DocuControl (.171)	■ weiterhin Xtend1478 (alt)	nicht erreichbar (anderes Netz, getmatic)
DocuPi-3000 (.83)	■ weiterhin Xtend1478 / unklar (alt)	nicht erreichbar (anderes Netz, zu Hause)
SMB-Konto 192.168.0.86 (docucontrol)	■ unverändert	kein Remote-Admin-Zugriff (RDP/ WinRM) von dieser Session

Diese drei Punkte sind keine technischen Hürden, sondern reine Erreichbarkeits-/Zugriffsfragen — sobald die Geräte im selben Netz oder über VPN erreichbar sind bzw. ein Admin-Zugang zum Windows-Rechner vorliegt, ist der Rollout identisch zum bereits durchgeführten durchführbar.

4. Offene Ports (aktueller Stand)

Port	Dienst	Bindung	Bewertung
22	SSH	0.0.0.0	✓ Key-only, individuelles Passwort
631	CUPS	127.0.0.1:::1	OK, lokal gebunden
5000	Flask HTTP (Kiosk)	0.0.0.0	OK, Access-Control gehärtet
5443	Flask HTTPS	0.0.0.0	OK, selbstsigniert
9100	TCP-Druckempfang	0.0.0.0	bewusst ohne Auth (Protokollformat)
34211	Docker-internes Loopback	127.0.0.1	unkritisch

~~111 (rpcbind)~~ — entfernt, nicht mehr gelistet.

Fazit

Für **Pi5_Display/docucontrol3** ist die Host-Ebene jetzt durchgängig gehärtet: individuelles, nicht-dokumentiertes Passwort, Key-only-SSH, keine unnötigen Netzwerkdienste. Das verbleibende Restrisiko (Docker-Privilegien, fehlendes fail2ban) ist bewusst und begründet zurückgestellt. Der einzige noch offene Punkt mit echtem Sicherheitswert ist der **Rollout auf die übrigen Flottengeräte** — das ist kein technisches, sondern ein Erreichbarkeits-/Logistik-Thema.

Dieser Bericht aktualisiert `docucontrol_owasp_host_sicherheitsbericht.md` nach dem Passwort-Rollout vom 22.06.2026. Es wurden ausschließlich Befunde erneut geprüft, die im Erstaudit identifiziert wurden — kein vollständiges Re-Audit "von Null".